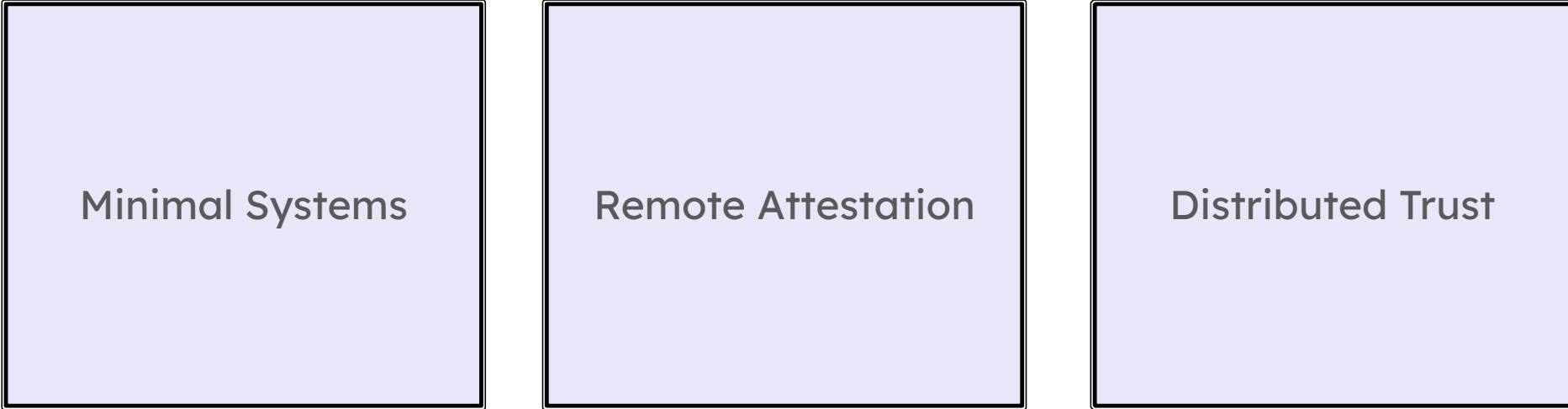


MFA System

Honours Project Presentation - Vidal S.G.



The core



Minimal Systems

Remote Attestation

Distributed Trust

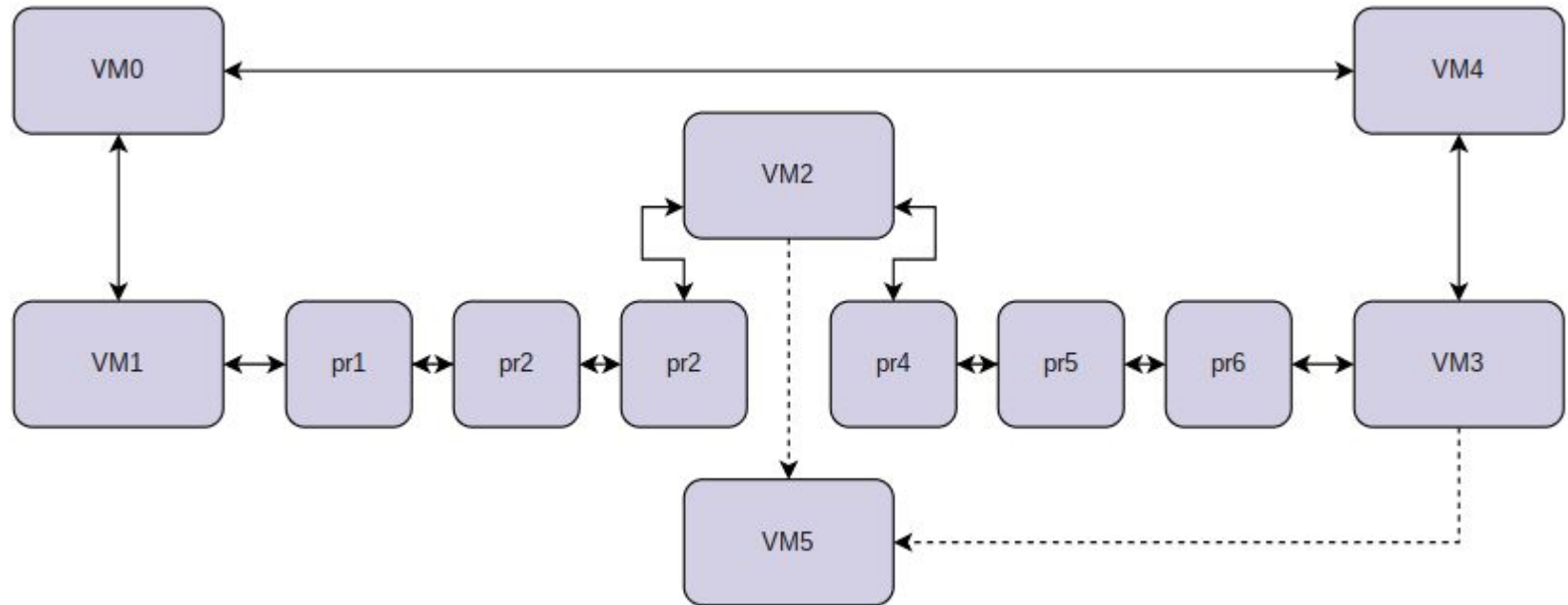
The Minimal System



gentoo linux™

- Local Compilation
- Explicit Inclusion
- Subsystem Elimination
- Kernel Hardening
- Community

System Topology



Cryptography

Crypto Component	Algorithm / Standard
Hybrid Post-Quantum KEM	ML-KEM-1024 (FIPS 203, Level 5) + X25519 (Curve25519 ECDH)
Key Derivation	HKDF-SHA256 (RFC 5869)
Data Encryption	AES-256-GCM
TPM Attestation Signature	RSA-2048 (RSASSA-PKCS1-v1_5)

Attestation A - Hardware identity

Platform Configuration Registers (0-7)

- Boot chain SHA-256 hashes, from hardware firmware to kernel handoff.
 - Measured by TPM during boot, read via **tss-easpi PcrRead**.
 - Mismatch indicates boot chain tampering or unauthorized kernel replacement.
-
- | | |
|---|---|
| → PCR0 = UEFI firmware code | → PCR4 = bootloader code (GRUB/EFI stub) |
| → PCR1 = UEFI firmware configuration | → PCR5 = bootloader configuration (GPT table) |
| → PCR2 = option ROMs and external drivers | → PCR6 = platform-specific (vendor) |
| → PCR3 = option ROM configuration | → PCR7 = Secure Boot policy |

Attestation A - Hardware identity

Attestation Key (AK) and TPM Quote Signature (SIG)

- A RSA-2048 key pair is generated by TPM, via **TPM2_CreatePrimary**.
- The private key never leaves the TPM, the public key is stored in baseline (AK).
- The attestation calls **TPM2_Quote**, TPM reads PCR values internally, concatenates to a fresh nonce generated by the attestator, and signs the digest using the private key.
- The verifier verifies the signature against the stored key (AK).
- Mismatch means different physical hardware responding or a forged signature.

Attestation B - Software Identity

Integrity Measurement Architecture (IMA)

- Hashes every binary, shared library, and script before execution, via hooks **sys_execve** and **sys_mmap**
- Measurements stored in: **/sys/kernel/security/ima/ascii_runtime_measurements**
- Kernel config: **CONFIG_IMA=y**, **ima_policy=tcb**
- Two values sent per heartbeat:
 - Count = total measurements since boot
 - d+N = new measurements since last heartbeat
- Proves exactly if files executed since boot and in the last interval.

Attestation B - Software Identity

Software-recomputed aggregate hash (AGG)

- Single SHA-256 hash covering the entire IMA measurement log from boot to present.
 - Computed as a chain: $H(H(\text{prev}) \parallel H(\text{measurement}))$.
- The node sends both the raw IMA log and its precomputed AGG to the verifier.
- The verifier independently recomputes the aggregate hash from the raw log, and compares it against the sent AGG.
- It proves the IMA log is complete, in order, and untampered per attestation.
 - Unlike TPM PCR 10, which provides a hardware-extended aggregate of IMA measurements that is non-resettable until the next reboot.

Attestation B - Software Identity

SHA-256 hashes of critical binaries (BIN and BINDIR)

- SHA-256 hashes of node-specific critical binaries compared against baselines

Binaries	Nodes
mfa-agent	All except VM5
mfa-monitor	VM5
mfa-logfwd	VM2 and VM3
cli-auth	VM0 and VM4
xdp-entropy.o and bpf-sysmon.o	All but different roles

Attestation C - Behaviour Identity

BPF Syscall Monitor (SYSM)

- A set of BPF tracepoint hooks attached to security-critical syscalls. Counters are cumulative since boot; the attestation sends deltas since last heartbeat.
 - Zero post-boot execve agent policy: after init completes, no new process execution should occur.

sys_enter_execve (execve)	Process execution
sys_enter_ptrace (ptrace)	Debugger attachment
sys_enter_mount (mount)	Filesystem mount
sys_enter_connect (connect)	Outbound connection
sys_enter_socket (socket)	Socket creation (exotic types)
sys_enter_openat (openat)	Sensitive file access

Attestation C - Behaviour Identity

File Descriptor Audit (FD)

- Enumerates **/proc/<pid>/fd** for every userspace process, classifying each open file descriptor as:
 - File: regular file on disk
 - Socket: network connection
 - Pipe: inter-process communication
 - Device: hardware (/dev/mem, /dev/tty, etc.)
- The total count of open FDs and their classification is sent per attestation.
- It proves no unexpected open file descriptors exist. A clean node has only predictable FDs: the agent's own sockets, log files, and a few system pipes.

Attestation C - Behaviour Identity

Kernel Integrity (KERN)

- Three checks to ensure no unauthorised kernel code is running:

Loaded BPF Programs (bpf)	BPF_PROG_GET_NEXT_ID enumeration	7 (1 XDP entropy filter + 6 sysmon tracepoints)
Kprobes (kp)	Read /sys/kernel/debug/kprobes/list	0 (any kprobe indicates runtime kernel patching)
Kernel modules (mod)	Read /proc/modules	empty

Attestation D - Network Identity

Entropy Filter (XDP)

- A BPF program attached at the network driver level (NIC ingress, before iptables and kernel stack, so local rootkits cannot bypass it). Analyses every TCP packet payload using a 256-bit stack bitmap to count unique byte values.
- Encrypted traffic (AES-256-GCM) produces 250+ unique bytes per 1500-byte payload.
 - 98% of encrypted traffic produces 250–259 unique bytes.
 - Minimum observed: 90 unique bytes (key exchange handshake).
- Traffic entering the node is either legitimate encrypted data (high entropy) or a recognised handshake (medium entropy). Low-entropy payloads are detected and blocked/flagged.
- A packet below threshold could indicate plaintext commands injection or a protocol downgrade attack forcing no encryption.

Attestation D - Network Identity

Firewall Rule Integrity (FW)

- Reads iptables filter table rules via **getsockopt** (IPT_SO_GET_INFO/IPT_SO_GET_ENTRIES) on raw sockets.

Connection Tuples (CONN) and Listening Ports (PORTS)

- Reads **/proc/net/tcp** (and **/proc/net/tcp6**) to extract the set of active TCP connections.
 - **CONN**: Each connection is normalised to a tuple: (local_addr:port, remote_addr:port).
 - **PORTS**: Extracts the list of sockets with local ports that are open and listening for incoming connections.

Attestation E - System Structure Identity

Entropy Pool (ENT)

- Read from `/proc/sys/kernel/random/entropy_avail`. Must be ≥ 128 bits for ML-KEM-1024 key generation (FIPS 203 requirement) and AES-256-GCM nonce generation. Low entropy = cryptographic operations may produce weak keys.

Process Masquerade Detection (MASQ)

- For every userspace process, reads `/proc/<pid>/status` to obtain its **PPid** (parent process ID). Verifies the parent exists and is an expected process (only `init`, or `mfa-agent`). Also allows to check if a process has renamed its **comm** or replaced its **executable path**.

Kernel Thread Types (KTH)

- Normalised list of kernel thread names (comm values) as seen in `/proc/[pid]/comm` for processes with `PID < 300` (typically kernel threads such as `kworker/0:0`). The set is compared against a baseline.

Attestation E - System Structure Identity

PW	Reads /etc/passwd
SSH	Reads /etc/ssh/sshd_config
PRE	Reads /etc/ld.so.preload
BOOT	Reads /proc/cmdline
DEV	Reads /dev
MOD	Ensures CONFIG_MODULES=n

MNT	Read /proc/mounts
CFG	Combined hash of /opt/mfa-agent/node.json , /etc/crontab , /etc/hosts , /etc/resolv.conf , /etc/hostname
SYS	Combined hash of net.ipv4.ip_forward net.ipv4.conf.all.accept_redirects net.ipv4.conf.all.send_redirects net.ipv4.conf.all.accept_source_route net.ipv4.tcp_syncookies kernel.kptr_restrict kernel.dmesg_restrict kernel.randomize_va_space fs.suid_dumpable
INIT	Combined hash of /etc/init.d , /etc/runlevels , /etc/local.d